

Business Logic Flaws

CompTIA PenTest+ (PT0-003)

Domain: 2.0: Reconnaissance and Enumeration

Objectives:

- 2.3: Given a scenario, modify scripts for reconnaissance and enumeration.
- 2.4: Given a scenario, use the appropriate tools for reconnaissance and enumeration.
- 4.10: Given a scenario, use scripting to automate attacks.

Video Overview

Welcome to this video on Business Logic Flaws! In this session, we'll explore a type of application vulnerability that arises from oversights in design rather than coding errors. As aspiring cybersecurity professionals or those looking to deepen their understanding of application security, recognizing and exploiting these flaws is a vital skill. We'll demonstrate how attackers can manipulate application workflows by taking advantage of flawed assumptions about user behavior and untrusted input. The techniques and tools covered, such as Burp Suite, are directly applicable to penetration testing in real-world scenarios and will enhance your ability to identify and report significant vulnerabilities, preparing you for tasks you might encounter in your future careers. This understanding is key to securing applications effectively and contributing to a more robust digital landscape.

Key Topics Covered

- Application Logic Flaws: Bypassing intended steps or performing unauthorized actions within a web application's design.
- Root Causes of Logic Flaws: Fundamental oversights during application development, often stemming from bad assumptions about user interaction.
- Trusting User Input: The principle of never fully trusting data provided by users, as it can lead to malicious manipulation.
- Using Burp Suite: Intercepting and analyzing communication between a browser and web application, capturing POST requests.
- Burp Suite Repeater: Modifying and resending captured requests to identify and exploit vulnerabilities.
- Authentication Bypass Flaws: Manipulating session tokens or user IDs to gain unauthorized access.

- Unauthorized Feature Access: Altering parameters in requests controlling administrative functions or sensitive data to identify privilege escalation.
- Reporting Vulnerabilities: Identifying and accurately reporting application logic breakdowns to customers for effective security.

Student Notes Section